



ID.me Identity Gateway Credential Policy

Doc ref: ID.me.S.00.010
Version: v10.1
Published: 2024-07-01

Notice

- 1) References to Kantara SAC are made within this document for the purposes of showing a conformity mapping. They are placed right-justified after any clauses (single or multiple) to which the conformity cross-reference applies, in the following fashion:

KI: «criterion reference»; «criterion reference»; etc.

- 2) References to IS27001 [10] are made within this document for the purposes of showing an intended conformity mapping. They are placed right-justified after any clauses (single or multiple) to which the conformity cross-reference applies, always at the lowest indexed level to which they apply, in the following fashion:

IS27001: §«clause reference»; A«Annex A reference»; etc.

Key Words

The key words "SHALL", "SHALL NOT", "SHOULD", "SHOULD NOT", and "MAY", when used in capitals within this Policy, are to be interpreted as described in RFC 2119 [13], the applicable parts of which are:

- a) SHALL This word means that the statement is an absolute requirement of this Policy;
- b) SHALL NOT This phrase means that the statement is an absolute prohibition of this Policy
- c) SHOULD This word means that there may exist valid reasons in particular circumstances to ignore the statement, but such a course of action is not recommended;
- d) SHOULD NOT This phrase means that there may exist valid reasons in particular circumstances when the behavior described by the statement is acceptable or even useful, but it is not generally recommended;
- e) MAY This word means that the statement is truly optional.

The Key Words "PRIMARY" and "SECONDARY", when used in capitals within this Policy, are to be interpreted as described in NIST SP 800-63 revision 3 [5] in the context of forms of identity evidence described therein as "STRONG" and "FAIR", respectively. These requirements can be summarized as:

- a) PRIMARY evidence must be government-issued (by a Federal or a State entity) and bear an item of the subject's biometric information, typically a photograph;
- b) SECONDARY evidence can be issued by a government entity or an entity with some widely-recognized standing, e.g. a financial institution or utility services provider, which can be corroborated with the PRIMARY evidence also provided. It need not include any biometric information.

Further details of acceptable forms of evidence are given further in this policy and during the proofing process.

Table of Contents

Table of Contents	3
1 Introduction	6
1.1 Overview	6
1.2 Policy Identification	6
1.3 IdP Roles	7
1.3.1 Subject	7
1.3.2 Relying Party	7
1.3.3 Trusted Referee Rules	8
1.3.4 Referee Organization	8
1.3.5 Trusted Referee	8
1.3.6 Authoritative Source	8
1.4 Credential Usage	8
1.5 Policy Administration	9
1.5.1 Organization Administering the Document	9
1.5.2 Review and Approval	9
1.5.3 Revision Notification	9
1.5.4 Changes in this Revision	9
2 Publication and Repository Responsibilities	9
3 IdP Credential Enrollment and Issuance	10
3.1 Subject Naming	10
3.2 Initial Registration	10
3.2.1 Account Sign-up	10
3.2.2 Account Creation	11
3.2.3 Sign-on/Password Strength	12
3.2.3.1 Social Media Account	12
3.2.3.2 Software or Hardware token	12
3.2.3.3 User-created Password	12
3.2.3.4 User Password Limitations	12
3.2.4 Identity Proofing & Verification	12
3.2.4.1 Required Evidence	12
3.2.4.2 Unsupervised Proofing	13
3.2.4.3 Supervised (Remote & In-person) Proofing	14
3.2.4.4 All Proofing Classes	14
3.2.4.5 Identity Evidence Validation and Verification Sources	15
3.2.4.6 Elective Deletion of Image Records	15
3.2.5 Credential Acceptability	15
3.2.6 Credential Activation and Use	15
3.2.7 Credential 'Step-up'	16

3.2.8 Credential Re-issuance and Renewal	16
3.2.9 Registration Records	16
3.3 Authentication Protocols	16
3.3.1 End User Authentication	16
3.3.2 Content	17
3.3.3 Protection	17
3.3.4 Assertion Lifetime	18
3.3.5 Single Use	18
3.3.6 Reliability	18
3.3.7 Re-Authentication	18
4 Credential Lifecycle	18
4.1 Terms of Service Validity Period	19
4.2 Authentication Process	19
4.3 Credential Status Availability	19
4.4 Lifecycle Events	19
4.4.1 Credential Activation/Re-Activation	19
4.4.2 Failed Authentication	20
4.4.3 Suspension after inactivity	20
4.4.4 Modify Account Information	20
4.4.5 Password Reset	21
4.4.6 Revocation	21
4.4.6.1 Circumstances for Revocation	21
4.4.6.1.1 Revocation Request from End Users	21
4.4.6.1.2 Revocation Request from Non-Users	21
4.4.6.1.3 Revocation Request from Authorized Bodies	21
4.4.6.1.4 Revocation by ID.me	22
4.4.6.2 Revocation Response Time	22
4.4.6.3 Revocation Notification	22
5 Facility and Operational Controls	22
5.1 Physical Controls	22
5.1.1 Physical Access Controls	22
5.1.2 Secure Disposal	23
5.2 Procedural and Personnel Controls	23
5.2.1 Security Roles and Responsibilities	23
5.2.1.1 Trusted Roles Requirement	23
5.2.1.2 Personnel Resource Requirements	24
5.2.2 Personnel Qualifications	24
5.3 Event Logging	24
5.3.1 Types of Events Recorded	25
5.3.1.1 End User Sign-up	25
5.3.1.2 Credential Revocation	25

5.3.1.3 Credential Status Changes	26
5.3.1.4 Trusted Referee Assignments	26
5.3.2 Security Incidents	26
5.4 Risk Assessments	26
5.5 Records Protection and Retention	27
5.5.1 Record Protection	27
5.5.2 Record Retention Period	27
5.6 Business Continuity	27
5.7 Availability of Services	27
5.8 Termination of Services	27
6 Technical Security Controls	28
6.1 Network Security	28
6.2 Key Management	28
6.3 Information Security Management and Lifecycle Controls	28
7 Applicable Standards	29
7.1 Internal Service Audit	29
7.2 Referee Organization Audits	29
7.3 Audit Records	29
7.4 Other notifications	29
8 Exceptions	30
8.1 Discrete exceptions	30
9 References	31
10 Revision History	33

1 Introduction

1.1 Overview

This document sets forth the Credential Policy (CrP) for ID.me's Identity Gateway id-proofing and credential management services. It follows the general structure of RFC 3647 [1].

ID.me's **Identity Gateway** provides businesses' and government agencies' communities and our nation's veterans, first responders, and members of other designated groups (eligible parties) with a simple and secure way to verify their identities remotely, for online transactions, while minimizing the risk of identity theft. ID.me's **Identity Gateway** protects a user's identity while simultaneously providing assurance to businesses and government agencies (Relying Parties) that the user's identity and group status are reliably verified by an authoritative source. These assurances allow for participants to confidently complete electronic transactions in a secure environment. Use of the **Identity Gateway** provides eligible parties access to certain benefits, discounts, and information from various organizations who wish to limit access based on requirements related to the underlying value and eligibility associated with the benefit, discount, or information.

Assurance Levels (ALs – known synonymously as Levels of Assurance (LoA) in the context of 'Classic'/NIST SP 800-63 rev.2 services) relate to the degree of confidence in a claimed identity and associated characteristic attributes and the associated technology and processes governing the operational environment. Assurance Levels are defined in a number of key documents, principally OMB M-04-04 [2] and NIST SP 800-63r2 [4], OMB M-19-17 [12] and NIST SP 800-63r3 [5], ISO 29115/ITU-T X.1254 [3], and the Kantara Initiative's SAC [7a – 7e inclusive]. Choice of ALs is determined by the service's Relying Parties, according to the level of confidence or trust (i.e., assurance) they deem necessary to mitigate risk in their transactions.

This service policy covers End User credentials issued at LoAs 1 & 3 and at 'x'AL1 & 2 (see §1.2). It details how ID.me provides to eligible parties, through both a supervised in-person process and via an unsupervised online process, a credential that can be trusted by Relying Parties consistent with the Assurance Level of the credential. How an enterprise becomes a Relying Party is not covered by this CrP.

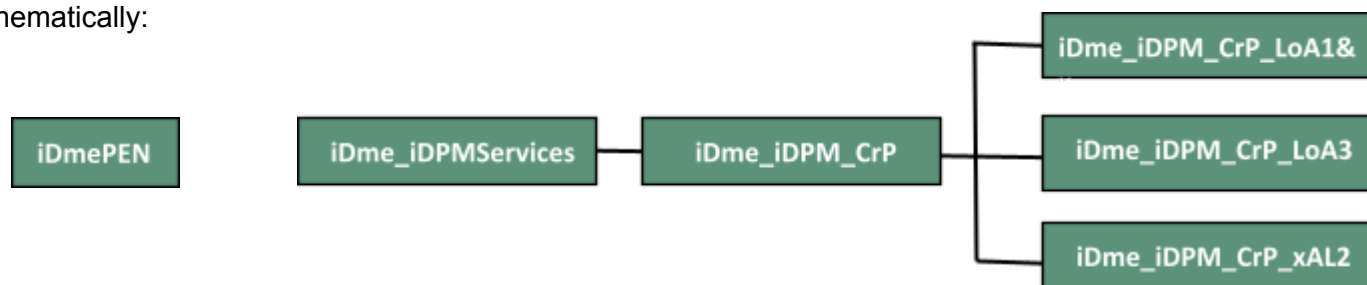
1.2 Policy Identification

- a) This document and the derived policies SHALL be formally identified by their applicable full title and Policy OID. The OID path for this policy document is described in the following table and derives from assignments given in the 'ID.me.C.00.005 PEN Register'. Assertions relating to credentials issued according to practices described in this CrP SHALL be identified by at least one of the following Policy OIDs:

Element	Path / OID	Policy Title
iDme_iDPM_CrP	::= { iDme_IdPMServices.1 } (1.3.6.1.4.1.43927.10.1.1)	ID.me Identity Proofing & Management Service Credential Policy (<i>this document</i>)

iDme_iDPM_CrP_LoA1&xAL1	::= { iDme_iDPM_CrP.1 } (1.3.6.1.4.1.43927.10.1.1.1)	ID.me Identity Proofing and Management Service Credential Policy – OMB M-04-4 Assurance Level 1 and SP 800-63 rev.3 Identity & Authentication Assurance Level 1
iDme_iDPM_CrP_LoA3	::= { iDme_iDPM_CrP.3 } (1.3.6.1.4.1.43927.10.1.1.3)	ID.me Identity Proofing and Management Service Credential Policy – OMB M-04-4 Assurance Level 3
iDme_iDPM_CrP_xAL2	::= { iDme_iDPM_CrP.4 } (1.3.6.1.4.1.43927.10.1.1.4)	ID.me Identity Proofing and Management Service Credential Policy – SP 800-63 rev.3 Identity & Authentication Assurance Level 2

Schematically:



KI: OPB#0010, 63B#0030

Unless explicitly qualified, either by reference to OID/title or by scope, all statements in this overall Credential Policy relate to all 'iDme_iDPM_CrP' policies.

This Policy Identification Schema has no provision for the identification of credentials intended for use in specific Federations, since such identification is likely to be the remit of the applicable Federation Authority and thus beyond the scope of this Policy.

1.3 IdP Roles

This section provides a brief description of each IdP role. The specific obligations of each role are more fully discussed later in this document.

1.3.1 Subject

An individual person to whom a credential has been issued (assuming them to have successfully passed identity proofing and verification processes).

Syn. **End User.**

1.3.2 Relying Party

A Partner enterprise or other entity which uses ID.me's **Identity Gateway** services to gain assurance at a defined AL as to a **Subject's** identity and their eligibility for such services as the Relying Party may offer. Generally abbreviated to 'RP'.

1.3.3 Trusted Referee Rules

A set of documented rules in accordance with applicable laws, regulations, and policy, which establishes how an ID.me representative may operate so as to validate and verify an Applicant as meeting the proofing requirements for an IAL2 credential. This titling is a combination of Proofing Supervisor and Trusted Referee functions associated with proofing processes described in NIST SP 800-63 revision 3 [5].

1.3.4 Referee Organization

An entity which has, through a contract with ID.me, agreed to implement specific **Referee Rules** through which it will notify to ID.me the required details of each attempt to perform identity proofing of an Applicant for an IAL2 credential (derived from NIST SP 800-63-3 of revision 3 [5]).

1.3.5 Trusted Referee

An individual who meets the requirements of specific **Referee Rules** and is able to act in a Supervisory capacity in support of Applicants undergoing identity proofing at IAL2 (modified from NIST SP 800-63-3 of revision 3 [5]).

Syn **Proofing Supervisor**.

*Note – such persons may be employed directly by ID.me or may act through a **Referee Organization**.*

1.3.6 Authoritative Source

A repository which is recognized as being an accurate and up-to-date source of information which may be used to validate information provided by the applicant **Subject**. [ISO/IEC 29115:2011]

1.4 Credential Usage

An ID.me identity credential is issued to an End User in order for them to be authenticated by an eligible Relying Party with whom they wish to perform some transaction or exchange. Typically, Relying Parties will direct End Users to ID.me to perform their initial Sign-up and will specify the Assurance Level (AL) at which it requires credential issuance and authentication services for its specific website(s) or service(s).

Relying Parties only use authentication assertions only at the specified AL or lower and should not rely on an assertion for any service, exchange or transaction offered or transacted at a higher AL than that specified in the ID.me assertion, nor should they rely upon the assertion beyond its stated life-time.

Relying Parties SHALL determine by contract or other 'non-dynamic' agreement with ID.me the policy/ies under which they expect credentials to be issued and/or to be authenticated.

1.5 Policy Administration

1.5.1 Organization Administering the Document

This document SHALL be administered by ID.me Inc., whose offices are located at:

8280 Greensboro Drive, Suite 800
McLean, VA 22102, USA.
CProdO@ID.me

1.5.2 Review and Approval

This document SHALL be reviewed at least annually to ensure its continued accuracy, completeness and suitability. ID.me's ISGF SHALL review and agree changes to this document, the final authority being the ISGF Chair or their designee.

KI: CO#0150, ' #0160; OPA#0030

1.5.3 Revision Notification

ID.me SHALL post all revisions to this CrP. Material revision to this CrP SHALL be posted such that interested parties receive due notification of changes.

KI: CO#0080 ' #0090

1.5.4 Changes in this Revision

The following MATERIAL changes are embodied in this revision:

- a) references amended to accommodate errata, revisions and rescissions;
- b) refined definitions for 'Trusted Referee' and 'Referee Organization'

The following NON-MATERIAL changes are embodied in this revision:

- c) Formatting clean up.

2 PUBLICATION AND REPOSITORY RESPONSIBILITIES

- a) ID.me SHALL publish details of its Credential Policy as well as other terms of service, pursuant to the policy statements herein and such additional material as may be required to fully advise all interested parties as to the services characteristics and the terms of its provision with regard to legislative, Terms of Service and policy obligations. These publications SHALL be maintained such that they always reflect the service as being operated at any given time;

KI: CO#0080, ' #0090 a – e, j); OPB#0030

- b) ID.me SHALL maintain an internal repository of only that information relating to individual

credentials, their statuses and the Subject's characteristic attributes and eligibilities which is necessary to deliver the service and comply with legislative, Terms of Service, contractual and policy obligations;

KI: OPE#0010, '#0030, '#0040; OPB#0250

- c) ID.me SHALL require the End Users to acknowledge and authorize publication of their personal information to each RP with whom they interact.

KI: OPB#0480

3 IdP Credential Enrollment and Issuance

3.1 Subject Naming

- a) ID.me's **Identity Gateway** SHALL support the following Identity Proofing modes:
 - i) under policy *iDme_iDPM_CrP_LoA1&xAL1*, only Unsupervised proofing;
 - ii) under policy *iDme_iDPM_CrP_xAL2*, Supervised (Remote), Supervised (In-person) and Unsupervised proofing.
- b) Under all policies, End Users SHALL be bound to their credentials at least by means of an email address, possession and control of which they SHALL demonstrate before being granted full access to services;
- c) At LoA1 and AL1, under policy *iDme_iDPM_CrP_LoA1&xAL1*, single factor authentication SHALL be provided. The email address provided need not bear any relation to the End User's actual identity and no real identity SHALL be required or be verified;
- d) At LoA3 and IAL/AAL2, under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2*, it SHALL be ensured that End Users provide a legal name that passes identity verification checks and that two- factor authentication is established;
- e) All bound email addresses SHALL be unique within the **Identity Gateway** service.

KI: 63A#0260

KI: OPB#0020; OPB#0300

3.2 Initial Registration

3.2.1 Account Sign-up

- a) under policy *iDme_iDPM_CrP_LoA1&xAL1* only, End Users SHALL be permitted to sign-up for a credential directly at www.id.me or account.id.me. Therefore only Unsupervised proofing is supported by this policy;

KI: OPB#0050

- b) to be issued with a credential under any policy except *iDme_iDPM_CrP_LoA1&xAL1*, End Users SHALL be directed to ID.me's identity authentication services by a Relying Party. The RP SHALL, at the time or by prior determination, specify the required policy;
- c) under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2*, the RP SHALL determine whether to direct the applicant End User to a location where Supervised (Remote) proofing can take place or whether to direct them to the **Identity Gateway** portal for Unsupervised proofing. Unsupervised proofing will be the principal means by which an End User signs-up;

KI: OPB#0050
- d) during any sign-up process, the applicable Terms of Service, Privacy Policy and this Credential Policy SHALL be made accessible, as SHALL be any additional policies which are deemed to be significant in terms of the provision of the service;
- e) The End User SHALL be presented with and SHALL be required to accept all applicable terms of service, etc. (see item "d") before they are required to provide any sign-up information.

KI: OPB#0050; CO#0080
- f) The service SHALL NOT be provided to persons under the age of eighteen years on the date of application.

KI: 63A#0080 c), '#0610

3.2.2 Account Creation

- a) Account creation SHALL be initiated by having the End Users provide an email address which SHALL be unique within the service as a whole (i.e. may not be used multiple times for different ALs). This email address must be associated with either:
 - i) a password; or
 - ii) an attestation of authentication via a third party provider recognized by ID.me (hereafter 'federated authentication');

KI: OPA#0050; OPB#0020; OPB#0300, 63B#0020
- b) End Users SHALL be required to accept the applicable Terms of Service and Privacy Policy and this Credential Policy, as well as such additional policies as may be deemed to be significant in terms of the provision of the service, before the sign-up process is concluded. Record of the End User's acceptance and the date of acceptance SHALL be retained;

KI: CO#0120 a), '#0130
- c) An email SHALL be sent to the End User requiring them to confirm their email address before any identity proofing is performed.

3.2.3 Sign-on/Password Strength

End Users SHALL be permitted to sign-on to the service by [any | one] of the following means:

3.2.3.1 Social Media Account

Social media accounts MAY be used as an SSO option where the password strength of the specific service is deemed to be of sufficient strength for the applicable Assurance Level. Acceptable accounts SHALL be clearly notified to End Users.

3.2.3.2 Software or Hardware token

End User-provided software or hardware tokens MAY be used where the token strength of the specific device is deemed to be of sufficient strength to meet the applicable Assurance Level. Acceptable tokens SHALL be clearly identified for End Users.

3.2.3.3 User-created Password

When neither of the preceding options are employed End Users SHALL be required to create for their account a password (a.k.a 'memorized secret') which meets the following requirements:

- a) have a minimum of 10 characters but may be up to 128 characters;
- b) consist of any characters available to the user, without limitation;
- c) not be included in a dictionary of most commonly used or weak passwords; and
- d) is not included in a dictionary of passwords obtained from previous breach corpuses.

KI: OPA#0050; OPB#0020; OPB#0300; CO#0120 a), '#0130, 63B#0410, '#0460, '#0500

3.2.3.4 User Password Limitations

- a) User-created passwords SHALL NOT be truncated - all entered characters SHALL be required and saved for comparison when subsequently used for authentication purposes;
- b) Users SHALL NOT be given any support for storing password hints and thus SHALL NOT be given prompts or hints when entering their passwords for authentication purposes.

KI: 63B#0450

KI: 63B#0480, '#0490

3.2.4 Identity Proofing & Verification

3.2.4.1 Required Evidence

Under all policies except *iDme_iDPM_CrP_LoA1&AL1* identity proofing SHALL require the End User's provision of a minimum of two forms of evidence which provide or support the following information:

- a) legal given and family names;
- b) full postal address (including street number, street name, city, state/province, postal/zip code and country);
- c) date (year, month and day) of birth (DoB);
- d) Unique individual identifier such as Social Security Number (SSN), passport number, Individual Taxpayer Identification Number (ITIN), or similar;
- e) phone number.

The number of forms of evidence required SHALL fulfill the applicable Assurance Level and reference standards or criteria.

3.2.4.2 Unsupervised Proofing

- a) Under policy *iDme_iDPM_CrP_LoA1&AL1* no identity proofing SHALL be performed;
- b) Under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2* Unsupervised identity proofing forms of evidence required SHALL be two PRIMARY (a.k.a. STRONG) or one PRIMARY and two SECONDARY (a.k.a. FAIR);
- c) Acceptable forms of PRIMARY and SECONDARY evidence SHALL be documented and published in the public domain. PRIMARY forms of evidence must include a photo likeness of the subject;
- d) Identity proofing SHALL be performed by validating the End User-provided information against Authoritative Sources (which may be an issuing source or one capable of applying checks to verify the authenticity of submitted information);
- e) The extent of the validation SHALL be commensurate with the applicable technical standards on which implementation of the policy is based, accounting for the means of validation which are practically available to ensure adequate coverage of the expected user community;
- f) Additional 'knowledge-based' checks MAY be applied where other means do not provide a sufficient degree of confidence in the claimed identity and they are permitted by the applicable technical standards;
- g) A notification of pass or fail SHALL be provided to the RP or End User, depending on how account creation was initiated.
- h) Under policy *iDme_iDPM_CrP_xAL2*, the Applicant SHALL be directed to a Trusted Referee for Supervised (Remote) Proofing (see 3.2.4.3) to attempt a successful outcome when either a) the Applicant requests to be processed by a Trusted Referee or b) when Unsupervised validation fails and the Applicant agrees to being transferred to a Trusted referee.

3.2.4.3 Supervised (Remote & In-person) Proofing

The following SHALL apply under policy *iDme_iDPM_CrP_xAL2* for Supervised (Remote & In-person) proofing:

- a) Rules under which Trusted Referees operate SHALL be documented and made available as necessary;
- b) These Rules SHALL define, as a minimum:
 - i) specific professional roles or other attributes nominees need to hold to qualify;
 - ii) specific training nominees must undergo and/or other qualifications/certification nominees must hold;
 - iii) processes by which suspension and/or revocation (voluntary or involuntary) of Trusted Referee status will be accomplished;
 - iv) periodical re-qualification, unless met by continuing education, of the nominee, at a period not greater than 24 calendar months from last appointment/re-qualification;
 - v) any restrictions or exceptions, and how they will be handled.

KI: 63A#0590

- c) A notification of pass or fail SHALL be provided to the RP or End User;
- d) The Trusted Referee SHALL authenticate the proofing event irrespective of its outcome and record SHALL be retained of the Trusted Referee's identity and location at which the proofing took place;

KI: 63A#0330

- e) Referee Organizations SHALL be bound by the Rules which they SHALL meet by same or equivalent means.

KI: 63A#0330

3.2.4.4 All Proofing Classes

- a) Forms of evidence bearing an expiration date SHALL NOT be accepted beyond that date;
- b) On completion, all information not required for ongoing compliance/conformity fulfillment, fraud mitigation, and/or management of the credential SHALL be securely purged;

- c) Retained End User-provided information and any additional information received from authoritative sources SHALL be used in accordance with ID.me's Privacy Policy and SHALL only be used in the identity proofing process to establish ownership of the identity commensurate with the rigor required of the applicable policy;
- d) Identity proofing SHALL NOT be based on the applicant End User's entitlement to participate in any particular group or community or gain access to any services or benefits.
- e) the End User MAY be asked questions to which only they should reasonably know the answers (Knowledge-Based Verification), but in doing so the service SHALL meet the requirements of any applicable standards.

3.2.4.5 Identity Evidence Validation and Verification Sources

ID.me SHALL use external sources for the purposes of validating and verifying identity proofing evidence only after due diligence has been exercised to ensure that the sources maintain ethical practices and observe applicable legislation with regard to the protecting of PII and ID.me's business interests.

3.2.4.6 Elective Deletion of Image Records

Once the identity proofing process has reached a conclusion (success or failed proofing), the End User SHALL be given a mechanism to request deletion of image records provided during the identity proofing process in accordance with §5.1.2, unless retention is required as noted and governed by the Privacy Policy.

3.2.5 Credential Acceptability

- a) credentials MAY be software-based;
- b) credentials SHALL conform to any applicable standards.

KI: 63B##0230, '#1690 b)

3.2.6 Credential Activation and Use

- a) Under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2*, a credential SHALL become active when identity proofing and verification have been successfully completed;

KI: OPB#0130

- b) Under all policies except *iDme_iDPM_CrP_LoA1&AL1*, in addition to successfully completing identity proofing and verification, a possession-based second-factor authenticator SHALL be established before activating the credential.

KI: OPB#0130; 63A#0280, 63A#0450, 63B#0050, '#0230, '#1760

3.2.7 Credential ‘Step-up’

End Users SHALL be able to ‘step-up’ the assurance level of their credential at any time by successfully completing the necessary additional steps to achieve their desired assurance level.

KI: OPB#0130, 63B#0820, '#1800, '#1810 b)

3.2.8 Credential Re-issuance and Renewal

End Users SHALL be able to reset their passwords online after being authenticated using their existing password and any other authentication factors. In the case of a forgotten password the, 63B#0820y SHALL be able to effect a reset by receiving a link to a reset page. In each case, if the credential was issued under policies *iDme_iDPM_CrP_LoA3* or *iDme_iDPM_CrP_xAL2*, the End User SHALL additionally be subjected to second factor authentication via a secure means.

If the reset fails then Users SHALL be directed to Member Support for assisted authentication, before the reset is enabled.

KI: CO#0090

3.2.9 Registration Records

Irrespective of the outcome of the identity proofing, records of the identity proofing and verification process, of renewals and re-issuances, references of source documents, identity of Authoritative Sources, verification outcomes, and a time-stamp, SHALL be kept in accordance with §6.3.

KI: CO#0140, '#0250; OPB#0230, '#0260; OPC#0050; OPD#0060, 63A#0130

3.3 Authentication Protocols

3.3.1 End User Authentication

- a) Only credentials which are active SHALL be authenticated;

KI: OPF#0040, 63B#0040

- b) Under policy *iDme_iDPM_CrP_LoA1&AL1* each instance of an End User presenting their credential will require their authentication based upon their associated password or federated authentication;

KI: OPF#0050, 63B#0040

- c) Under all policies except *iDme_iDPM_CrP_LoA1&AL1*, each instance of an End User presenting their credential SHALL require their authentication based upon their associated password or federated authentication, and their possession-based second-factor authenticator;

KI: OPF#0050, 63B#0040, '#0050

- d) At all ALs a maximum of 100 failed authentication attempts SHALL be permitted within a 30-day period.

KI: OPF#0050, '#0070, 63B#0040, '#0510, '#0800, '#0930

- e) At all ALs authentication SHALL be performed at the requested AL or higher.

KI: 63B#0010, 63B#0040

3.3.2 Content

- a) Assertions SHALL have default inclusions and SHALL be able to convey further data on request of the RP, subject to the End User's authorization and compliance with applicable legislation;

KI: OPF#0140, 63B#0360 - '#0380

- b) Default inclusions under policy *iDme_iDPM_CrP_LoA1&AL1* SHALL be:

- i) the unique identifier for the intended RP;
- ii) AL at which the credential was issued;
- iii) unique End User identity;
- iv) assertion lifetime.

KI: OPF#0140, 63B#0020

- c) Default inclusions under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2* SHALL be:

- i) the unique identifier for the intended RP;
- ii) AL at which the credential was issued;
- iii) unique End User identity;
- iv) verified End User names;
- v) assertion lifetime.

KI: OPF#0140, '#0150

3.3.3 Protection

- a) Cryptographic protections SHALL be employed to ensure that Assertions SHALL be strongly-bound to individual RPs, signed and encrypted, and transmitted through secured, mutually-authenticated communications. Additionally, RPs SHALL be associated with pre-defined end-points;

KI: OPF#0120, '#0170, '#0180, '#0190, '#0220, 63B#0040, '#0900, '#1740

- b) Cryptographic techniques employed SHALL be selected from those listed as approved under the Cryptographic Module Validation Program.

KI: OPF#0120, 63B#0040, '#0900, '#1740, '#1760 b)

3.3.4 Assertion Lifetime

Assertions SHALL have a lifetime of not greater than 5 minutes and be valid only for the Relying Party's domain.

KI: OPF#0080

3.3.5 Single Use

Each assertion SHALL apply only to a specific transaction and SHALL only be re-sent in connection with that transaction.

KI: OPF#0170

3.3.6 Reliability

Should there be any system failure during authentication, no assertion SHALL be generated.

KI:

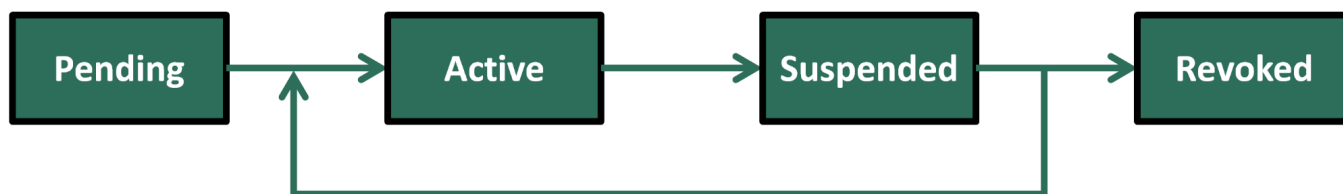
3.3.7 Re-Authentication

Re-authentication of a credential SHALL be permitted within 12 hours of an initial authentication so long as the session in which the original authentication took place remains active and the End User has been active within the last 30 minutes.

KI: OPF#0230, 63B#1940, '#1950

4 Credential Lifecycle

The status of a credential SHALL be maintained current in real-time, being recorded in one of the following states:



No publication of status SHALL be required since all credential management and authentication functions are handled internally by the ID.me service.

KI:

4.1 Terms of Service Validity Period

End Users must reaffirm their acceptance of the prevailing Terms of Service, Privacy and other Policies and any other required agreements at least once every 5 years. Credentials held by End Users who do not reaffirm their acceptance of all applicable terms within the 5 year period SHALL have their credential suspended. Any re-affirmation of acceptance of terms and policies, including accepting revisions to existing Terms of Service, Privacy and other Policies, SHALL lead to the credential validity being reset (and re-activated, if it has been suspended).

KI: CO#0120, OPC#0050

4.2 Authentication Process

- a) End Users SHALL be authenticated on behalf of Relying Party websites/applications, either by signing- on at the ID.me website or through a Relying Party's site;

KI:

- b) Under policy *iDme_iDPM_CrP_LoA1&AL1*, single-factor authentication SHALL be applied, requiring the End User to submit a username and a password or federated authentication which SHALL be matched against those associated with the account in the system database. On a successful match the authentication SHALL be complete;

KI:

- c) under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2*, two-factor authentication SHALL be applied, requiring the End User to first submit a username and a password or federated authentication which SHALL be matched against those associated with the account in the system database. On a successful match authentication using a possession-based second-factor authenticator SHALL be complete.

KI:

4.3 Credential Status Availability

A change in Credential status SHALL be available for immediate reference within the ID.me service. Credential status information SHALL NOT be generally published but a capability for qualified RPs to enquire of a credential's status MAY be provided.

KI:

4.4 Lifecycle Events

The following subsections describe events that occur over the lifecycle of the Credential and the effect (if any) on the state/status of the Credential and if/how such status affects the operation of the Credential.

4.4.1 Credential Activation/Re-Activation

The IdP Credential SHALL be placed in an “*Activated*” state in accordance with section 3.2. Activation is the process of binding the End User to the Account information (i.e., email address, postal address, phone number). If an IdP Credential is placed in an “inactive” or “revoked” state at any time over the course of its lifetime the End User SHALL undergo re-registration in order to restore the IdP Credential to an ‘Activated’ status.

4.4.2 Failed Authentication

Should authentication fail, up to nine further attempts are permitted before locking the credential. Unlocking the credential can happen either by a positive action by customer support personnel after a phone / email / multi-factor validation of the End User, unlocking the credential by proving ownership of the credential or expiry of a 72 hour time-out period, whichever takes place first.

4.4.3 Suspension after inactivity

If a credential issued under policy *iDme_iDPM_CrP_LoA3* remains unused (i.e. it is not presented and successfully used to authenticate the End User) for a period of eighteen months or longer it SHALL be suspended and SHALL require the End User to undergo re-registration in order to restore the IdP Credential to an 'Activated' status.

4.4.4 Modify Account Information

- a) The End User SHALL be able to modify their Account information to reflect changes in their personal circumstances or to correct errors. Prior to being able to effect changes the End User SHALL be required to sign-in to their account, accounting for the applicable AL. Users SHALL only be able to change the following information, according to the applicable AL, and SHALL require new and full identity proofing for fields so-marked:

Field / value	At all ALs
Email address	Validate new email per §3.1 & §3.2.2
Password	Validate new password per §3.2.2
Phone number	Validate new phone number per §3.2.2
Name	Validate new name per §3.2.2
Address	Validate new address per §3.2.2

- b) Once used an email address SHALL not be accepted for any new sign-ups or account modification.

4.4.5 Password Reset

In the event that their password is forgotten or compromised End Users SHALL be able to reset their password as addressed in §3.2.7.

KI:

4.4.6 Revocation

Revocation SHALL be supported under all policies. Following an initial revocation request a credential may be suspended while the revocation request is authenticated, but once determined authentic the status SHALL become 'revoked' and thereafter the credential SHALL not be used. Should a revocation request not be authenticated or be withdrawn before being fully applied the credential SHALL be re-activated.

4.4.6.1 Circumstances for Revocation

Revocation SHALL be permitted only under the following circumstances.

4.4.6.1.1 Revocation Request from End Users

- a) Under policy *iDme_iDPM_CrP_LoA1&AL1* the End User may request a revocation, which SHALL be confirmed by sending an email confirming the request to the email address of record;
- b) Under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2* End User revocation SHALL follow the same process as in a) above, and in addition a second-factor confirmation SHALL be required.

KI: 63B#1440, '1900 b)

4.4.6.1.2 Revocation Request from Non-Users

At all ALs there SHALL be a means by which a recipient of a confirmatory message can respond by stating that they have not requested that the account be created, in which case the associated credential SHALL be revoked.

KI: 63B#1900 b)

4.4.6.1.3 Revocation Request from Authorized Bodies

At all ALs there SHALL be a means by which an authorized body, e.g. law enforcement, a RP (for cause) or other body having a recognized authority, can request revocation. Each such requester SHALL be authenticated before any final action is taken. According to the authority and manner of request ID.me may suspend the credential pending further authentication and justification for the revocation, and SHALL either revoke or re-activate, according to its findings.

KI: 63B#1900 a), d)

4.4.6.1.4 Revocation by ID.me

ID.me SHALL revoke any credential, to accommodate instances of false representation,

failure to comply with Terms of Service, or for any other reason, at its sole discretion and at any AL.

KI: 63B#1900 c)

4.4.6.2 Revocation Response Time

Once a request has been authenticated revocation SHALL be effected immediately, and that status used in any subsequent authentication requests.

KI:

4.4.6.3 Revocation Notification

Once an End User's credential has been revoked all interested parties should be notified within 24 hours.

KI:

5 Facility and Operational Controls

5.1 Physical Controls

5.1.1 Physical Access Controls

- a) Production facilities SHALL be housed in secure data centers which provide for geographical alternate sites and are protected by multi-layer physical security, minimizing the opportunities for unauthorized access, disclosure, loss or corruption of sensitive and system information, and of IT resources on which the service is dependent. The site location and construction, when combined with other physical security protection mechanisms such as guards and intrusion sensors, SHALL provide robust protection against unauthorized access to the service's equipment and records and protection from adverse environmental conditions;

KI:
- b) Where third-party hosting is used, the ability of the entity to provide facilities which meet the above policy requirements SHALL be determined either by physical inspection by responsible ID.me personnel and/or through review of independent analyses and audits of the facilities in question. The findings from such determinations SHALL be documented and retained in accordance with the ID.me Retention Schedule;

KI:
- c) Development facilities (which SHALL not hold real client data) SHALL also be protected by multi-layer physical security, minimizing the opportunities for unauthorized access, disclosure, loss or corruption of sensitive and system information, and of IT resources on which development is dependent. Back-up / disaster-recovery sites SHALL have the same level of protection. A reduced level of security SHALL be permissible to the extent that no real client data is stored but must still be sufficient to ensure that the sensitivity of

proprietary information and the ability to support the production system is not compromised;

KI:

- d) Information and media transported between sites, and sensitive information and IT resources in the custody of staff, SHALL be protected from unauthorized access, disclosure, loss or corruption, having special regard for their use and potential storage in public areas (e.g. hotels, restaurants, car parks, ...);
- e) Back-up / disaster-recovery sites SHALL have the same level of protection as the primary site.

5.1.2 Secure Disposal

When it no longer serves a purpose or should not remain on any storage mechanism being serviced or repurposed, sensitive information SHALL be disposed-of using methods which meet or exceed the requirements of DOD 5220.22_M [7] or NIST SP 800_88 [8], ensuring that techniques applied match the storage media technology in use. Where third-party services are used, those entities SHALL guarantee and take responsibility for observing or exceeding those same requirements.

KI:

5.2 Procedural and Personnel Controls

5.2.1 Security Roles and Responsibilities

5.2.1.1 Trusted Roles Requirement

- a) The roles and responsibilities for personnel for each service-related and security-relevant task SHALL be documented. Such roles define positions which underpin the assurances given through the secure development, operations and delivery of ID.me's service and SHALL include as a minimum:
 - i) Executive and management functions;
 - ii) Engineering and development functions;
 - iii) System information security functions;
 - iv) Service administrative functions;
 - v) Member Support functions;
 - vi) Audit (both internal and external) functions.
- b) Personnel fulfilling such roles, both employees and contractors, SHALL be subject to appropriate HR procedures to ensure their character, qualifications and

KI: CO#0270

experience meet the documented requirements, including any specific clearances required by the role. Assignment of personnel to trusted roles SHALL be authorized by the ISGF Chairperson or his/her delegate.

KI: CO#0290, #0300

5.2.1.2 Personnel Resource Requirements

- a) The number of personnel required to effectively operate the service across development, operations and support functions SHALL be determined and suitable resources recruited and applied;

KI: CO#0310

- b) For highly-sensitive roles dual-personnel assignments and segregation of duties SHALL be designated and applied. No single person SHALL have more than one means of identifying themselves to the system.

KI: CO#0310

5.2.2 Personnel Qualifications

- a) HR policies SHALL provide for and apply adequate checking of personnel, concerning backgrounds, criminal records, qualifications and experience. Adequate training SHALL be provided to ensure that staff are competent to apply the tools used to develop, operate and support the service, including progressive training to ensure that state-of-the-art technologies and best practices are adopted and applied at all times;
- b) Such requirements SHALL apply to third-party personnel as well as ID.me's direct employees.

KI: CO#0290

5.3 Event Logging

- a) A log of all relevant security events SHALL be maintained, employing both automated and manual logging;
- b) Event logs SHALL be retained and protected against unauthorized access, loss or corruption and be available to support audit functions and any investigative processes, both internal and those conducted under lawful oversight. Event logs SHALL be retained for a minimum of five years, and otherwise as required by applicable legislation, contract or policy;
- c) Records SHALL be time-stamped at the time of their generation.

KI:

5.3.1 Types of Events Recorded

Logs SHALL capture at least the following events and associated information:

- a) any applicable event serial / sequence number (intended to provide a unique reference for the event, either as an instance, or to track an asset, e.g.);
- b) the date and time of the event;
- c) the nature of the event;
- d) the device, application, network or operating system, or person, identifying the event; and
- e) other pertinent information as further set out below.

5.3.1.1 End User Sign-up

The following information about End User sign-up SHALL be recorded, both at initial sign-up (whether successful or not) and for any subsequent changes, whether initiated by the service or the End User:

- a) the unique user id;
- b) references of any specific identifying information sources submitted, according to AL;
- c) references to how the identity information was verified;
- d) responses received to identity verification;
- e) associated device(s) (only under policies *iDme_iDPM_CrP_LoA3* and *iDme_iDPM_CrP_xAL2*);
- f) acceptance of applicable terms and policies;
- g) mode of proofing employed;
- h) if proofing is under policy *iDme_iDPM_CrP_xAL2* and is Supervised (Remote), the unique identifier of the supervising Referee Organization and Trusted Referee.

KI:

5.3.1.2 Credential Revocation

The following revocation information SHALL be recorded, whether fully prosecuted or not:

- a) the identity of the requesting source;
- b) the authority of the requesting source and measures taken to authenticate the source;
- c) the End User unique identity associated with the credential for which revocation is sought;
- d) the reason for revocation;
- e) the revocation decision (i.e. upheld – credential revoked; denied – credential reactivated).

KI:

5.3.1.3 Credential Status Changes

Any credential status changes between Sign-up and Revocation SHALL be recorded.

KI:

5.3.1.4 Trusted Referee Assignments

The following information about Trusted Referee (TR) Assignments SHALL be recorded, in addition to their supervisory actions cited in §5.3.1.1 above:

- a) the unique identifier of the TR;
- b) the identity of the nominating Referee Organization;
- c) each change of status, from initial 'Suspended', to 'Active', any intermediate 'Suspended' / 'Active' cycles, to final 'Revoked' status, with a reason in each case.

KI:

5.3.2 Security Incidents

- a) Controls SHALL be applied to provide prevention and detection of security incidents which could imperil the secure operation of the service, and alerts SHALL be provided based on defined thresholds of activity being exceeded, according to the nature of the event. Any significant events SHALL be logged and reviewed for signs of suspicious or unusual activity. Automated logs SHALL be continuously monitored to provide real time alerts;
- b) Records SHALL be kept of reviews of event logs and SHALL ensure that the integrity of logs remains preserved;
- c) Actions taken based on alerts and audit log reviews, and their outcomes, SHALL be documented and reviewed for completeness and effectiveness.

KI:

KI:

5.4 Risk Assessments

Risk Assessments SHALL be conducted at least every six months to ensure that any new threats are identified and that existing controls are providing a level of risk mitigation which is accepted by management, in accordance with the ISM Policy and ID.me's Statement of Applicability. Such risk assessments SHALL include a review of actual controls applied and SHALL be based on the service being classified as 'Moderate Assurance' at xAL2, in accordance with NIST FIPS 199 [10].

KI:

5.5 Records Protection and Retention

5.5.1 Record Protection

- a) Logical and physical access controls as required elsewhere in this CrP SHALL protect against unauthorized or unlawful access, use, disclosure, alteration, or destruction of any credential data repositories or credential management processes, whether records are stored on-site or by third parties;

KI: CO#0040, 63B#0180
- b) Where necessary, measures SHALL be taken to ensure the long-term accessibility of storage media over the required period.

KI: CO#0040, 63B#0180

5.5.2 Record Retention Period

Unless otherwise specified in this CrP, the default retention period for records SHALL be 36 months after account deletion/closure or a longer/shorter period if so dictated by other (overriding) policy, contract or legislation.

KI: OPB#0260, 63A#0120 c), '0170, 63B#0180, '0190

5.6 Business Continuity

- a) The service SHALL be included within ID.me's overall Business Continuity Planning such that in the event of a significant disruption to operations, critical business activities can be resumed (if necessary) and continued;
- b) The production system SHALL plan for and be deployed such that there is an alternate site capable of picking-up the operational load until the disrupting event can be resolved. This SHALL include redundant capacities and mirrored or backed-up copies of critical information, such as End User and RP account data, logs, test data and procedures, system build and configuration records.

KI: IS27001: A.17

5.7 Availability of Services

The service SHALL employ redundancies and back-up measures which ensure its 99.9% availability, excluding scheduled maintenance time and events totally outside of ID.me's control.

KI:

5.8 Termination of Services

If it becomes necessary to terminate the service ID.me SHALL take reasonable measures to give notice to End Users, RPs, Referee Organizations, out-sourced providers and other interested parties. It SHALL then, after expiration of the notice period, effect the revocation of all End User credentials, any

PKI certificates which it uses to secure its operations and services, and to ensure the long-term preservation of all records, for their required retention period. This plan SHALL be outlined in the Terms of Service.

KI: CO#0050

6 Technical Security Controls

6.1 Network Security

- a) Communications between all service components outside of a common DMZ SHALL be encrypted and mutually-authenticated using protocols which meet or exceed recognized best practices for the threat scenario used by the risk assessment process;
- b) End User Sign-up SHALL be protected by end-end encryption such that all data transfers are secured;
- c) 24/7 automated monitoring and test script execution SHALL be maintained with automated notification to operational personnel. In addition, daily system management reports SHALL be produced, reviewed and protectively stored. These reports SHALL, as a minimum, address security events, transactions processed, system usage/capacity, availability.

KI:

KI:

6.2 Key Management

- a) Knowledge of private key activation codes SHALL be limited to a minimum group of personnel, on a need-to-know basis. There SHALL be provision for non-availability of code-holders so as to ensure that critical functions can be actioned when required without imperiling the service;
- b) On re-assignment or termination of any of those trusted roles there SHALL be a procedure to effect a code- or key-change;
- c) In the event that a key is compromised in any way it SHALL be replaced and the compromised key revoked.

KI:

KI:

KI:

6.3 Information Security Management and Lifecycle Controls

This CrP is governed by the ID.me ISM Policy and as such SHALL fall within its provisions for information security management practices. The principles of that policy and of IS27001 [11] SHALL apply to all requirements of and practices derived from this CrP.

KI: CO#0160, #0240, IS27001: §1

Authentication assertions SHALL conform to generally-recognized industry standards, as may be determined by business, service (product) or client requirements. Which optional fields or alternative modes are employed SHALL be clearly communicated to users in both design and implementation.

7 Applicable Standards

In the specific context of the provision of Identity Proofing and Credential Management services the practices implemented to fulfill this CrP SHALL adhere to the provisions of the following standards and assessment/approval regimes:

- a) NIST SP 800-53/171 at latest applicable version, for the purposes of maintaining FedRAMP Moderate Authorization
- b) NIST SP 800-63 revision 2 [4], for the purposes of maintaining Kantara 'Classical' Approval;
- c) NIST SP 800-63 revision 3 [5], for the purposes of maintaining Kantara 'NIST 800-63 rev.3' Approval;
- d) ANSI/ISO/IEC 27001:2013, [11], as information security management best practice;

KI: CO#0220, IS27001: §1

7.1 Internal Service Audit

There SHALL be an internal audit program covering the service's provision which SHALL be conducted at least annually and SHALL, as a minimum, ensure that the provisions of this Policy and its CrPS are being met in the service's provision.

KI: CO#0220, IS27001: §9.2

7.2 Referee Organization Audits

There SHALL be an audit program covering services provided by Referee Organizations which SHALL be conducted at least annually and SHALL, as a minimum, ensure that the subject Referee Organization is meeting all contractual obligations in the provision of services on behalf of ID.me.

KI: CO#0220, IS27001: §9.2

7.3 Audit Records

Records of all audits and supporting evidence SHALL be archived for a minimum of four years from the date of audit (Kantara Approval period plus 12 months). Such records SHALL be protected against unauthorized access, loss, alteration, public disclosure, or unapproved destruction in accordance with section 6.4.

KI: CO#0230

7.4 Other notifications

Stipulations relating to fees, insurances, warranties, disclaimers, limitations of liability, indemnities, terms of supply, termination, confidentiality, privacy, notices, amendments, dispute resolution, governing law and other representation and legal matters SHALL be presented in the service's Terms of Service, Privacy Policy and other documents, all of which SHALL be brought explicitly to the End User's attention (see also §3.2.2).

8 Exceptions

8.1 Discrete exceptions

Any discrete exceptions or waivers to this policy SHALL each be handled in accordance with ISM Policy §22.

KI:

9 References

Ref.#	Document / Source
[1]	Request for Comments (RFC) 3647, “Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework”, © The Internet Society (2003). http://www.ietf.org/rfc/rfc3647.txt
[2]	OMB M_04_4, “E_Authentication Guidance for Federal Agencies”, Office of Management and Budget, 2003_12_16. http://www.whitehouse.gov/sites/default/files/omb/memoranda/fy04/m04_04.pdf Retained for historical purposes but superseded by [12].
[3]	ISO/IEC 29115:2013 // ITU_T Rec. X.1254 (12/2011) “Information technology _ Security techniques _ Entity authentication assurance framework”, joint ISO / ITU_T publication ² . https://www.itu.int/rec/T_REC_X.1254_201209_l/en
[4]	Special Publication 800-63 revision 2, “Electronic Authentication Guideline”, National Institute of Standards and Technology, 2013-08. http://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800_63_2.pdf
[5]	Special Publication 800-63 revision 3, “Digital Identity Guidelines”, National Institute of Standards and Technology, 2017-06-22. https://pages.nist.gov/800-63-3/
[6]	No longer used http://www.idmanagement.gov/sites/default/files/documents/FICAM_TFS_ATOS.pdf
[7]	No longer current – see sub-parts below.
[7a]	Kantara Initiative “KIAF-1410 CO_SAC SAC & SoCA” at the latest applicable version. https://kantarainitiative.org/download/ki af-1410-co_sac-kantara-identity-assurance-framework-common-organizational-service-assessment-criteria-sac-statement-of-criteria-applicability-soca-excel-version/
[7b]	Kantara Initiative “KIAF-1420 OP_SAC SAC & SoCA” at the latest applicable version. https://kantarainitiative.org/download/ki af-1420-op_sac-kantara-identity-assurance-framework-operational-service-assessment-criteria-sac-statement-of-criteria-applicability-soca/

² Note that the foreword of the ITU-T version explains that that version has four differences from the ISO version.

[7c]	Kantara Initiative “KIAF-1430 63A_SAC SAC & SoCA” at the latest applicable version. https://kantarainitiative.org/download/ki af-1430-identity-assurance-framework-nist-sp-800-63a-service-assessment-criteria-sac-statement-of-criteria-applicability-soca/
[7d]	Kantara Initiative “KIAF-1440 63B_SAC SAC & SoCA” at the latest applicable version. https://kantarainitiative.org/download/ki af-1440-identity-assurance-framework-nist-sp-800-63b-service-assessment-criteria-sac-statement-of-criteria-applicability-soca/
[7e]	Kantara Initiative “KIAF-1450 63C_SAC SAC & SoCA” at the latest applicable version. https://kantarainitiative.org/download/ki af-1450-identity-assurance-framework-nist-sp-800-63c-service-assessment-criteria-sac-statement-of-criteria-applicability-soca/
[8]	DOD 5220.22_M, “Operating Manual”, National Industrial Security Program, 2006-02 modified 2013-03-_18. (Chapter 5, Section 7 applies, as referenced). http://www.dtic.mil/whs/directives/corres/pdf/522022m.pdf
[9]	Special Publication 800-88, “Guidelines for Media Sanitization”, National Institute of Standards and Technology, 2006-09. http://csrc.nist.gov/publications/nistpubs/800_88/NISTSP800_88_with_errata.pdf
[10]	Federal Information Processing Standard 199, “Standards for Security Categorization of Federal Information and Information Systems”, National Institute of Standards and Technology, 2004-02. http://csrc.nist.gov/publications/fips/fips199/FIPS_PUB_199_final.pdf
[11]	ANSI/ISO/IEC 27001:2013, “Information technology -- Security techniques -- Information security management systems – Requirements”, American National Standards Institute, 2013-10. http://webstore.ansi.org/RecordDetail.aspx?sku=ISO%2fIEC+27001%3a2013
[12]	OMB M-19-17, “Enabling Mission Delivery through Improved Identity, Credential, and Access Management”, Office of Management and Budget, 2019-05-21. http://www.whitehouse.gov/wp-content/uploads/2019/05/M-19-17.pdf
[13]	Request for Comments (RFC) 2119, “Internet X.509 Public Key Infrastructure Certificate Policy and Certification Practices Framework”, © The Internet Society (2003). https://tools.ietf.org/html/rfc2119 (as modified by RFC 8174 “Ambiguity of Uppercase vs Lowercase in RFC 2119 Key Words”, © 2017 IETF Trust, https://tools.ietf.org/html/rfc8174)

10 Revision History

Version	Date	Description / Comments	Approval
1.0	2014-07-24	Formally released (stand-alone – see CrPS as separate document)	Released under DoA
2.0	2014-08-11	Document reference added	Released under DoA
3.0	2014-11-05	Approved release	RGW
4.0	2015-02-11	Adoption of revisions resolved through PoT preparation	Approved by RGW with delegated authority of MST.
5.0	2015-09-02	Correction to proofing policy, to state practice already correctly applied (§3.2.3 b) v), §3.2.4 b)).	Approved by COO, on ISGF's recommendation.
6.0	2016-08-22	Revision to Id Proofing Policy parts	Approved by COO, on ISGF's recommendation.
7.0	2018-04-05	Revisions to address SP 800-63 rev.3 conformity, use of Trusted Referees for Supervised (In-person) proofing & Kantara '63 rev.3' Assessment.	RGW, with CTO's delegated authority
8.0	2018-11-13	Revisions to reflect changes to the 800-63 rev.3 proofing	Approved MAB (CTO) Ticket IS-97086
8.1	2020-01-03	Non-material changes to heading titles and alignment to Ops Man II format, for internal management. 'Push' to public-facing web-site not necessary.	Approved JW (GRC)
9.0	2020-12-23	Added explicit proofing requirement to validate against expiration date; added §10 <i>Exceptions</i>	Approved CPO (/s/ PSampath) ISGF#41

9.1	2022-05-05	Numerous updates due to retention changes as well as editorial clarification throughout.	TA (Dir GRC)
10.0	2023-02-04	Material revisions as documented herein Additional non-material refinements.	TA (Dir GRC)
10.1	2024-07-01	Minor clarifications and format clean up.	GRC

KI: CO#0160, IS27001: A.5.1.1